ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Red Lion / N-Tron NT24k Managed Gigabit Switch (+ N-Tron 7000) · Component type: **Network Device (NDR) - managed industrial Ethernet switch** · Target SL = SL 3

Where to work	The switch **web UI (HTTPS)** and **CLI (SSH)**; Administration/Security menus (user accounts, 802.1X/RADIUS, SNMPv3, MAC security, syslog); VLAN, N-Ring/RSTP/MSTP; monitored by **N-View / RLView**. Change the default login (admin/admin). No documented secure boot on this platform.
Ports / paths	**HTTPS 443** + **SSH 22** (management); **HTTP 80 / Telnet 23** (disable/redirect); **SNMP 161** (v1/v2/v3 - use v3); **Syslog 514**; RADIUS 1812/1813; TACACS+ 49; NTP/SNTP 123; 802.1X (EAPOL). Physical: RJ45/console, reset; DIN-rail/rackmount. Change the default IP.
Firmware / platform	Red Lion / N-Tron **NT24k** all-gigabit managed (or the older **N-Tron 7000**). Modern security stack (HTTPS/SSH/SNMPv3/802.1X/RADIUS/syslog) but **no documented secure boot / MACsec** - roots-of-trust rows are Partial (firmware provenance). Confirm model + firmware in the web UI; track Red Lion / CISA advisories.
How to read	Default read-only (web/CLI read-only account, read-only SNMPv3). Each row = native step-by-step (web/CLI) + command-level external-tool validation + pass. Write/exploit tools = isolated env + written authorization.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user I&A;	Confirm web (HTTPS) + CLI (SSH) require login and the **default admin/admin is changed**; use named user accounts; integrate **802.1X + RADIUS** for port/user authentication and (where supported) TACACS+ for admin auth. Disable HTTP/Telnet. **Test:** browse HTTP/Telnet -> refused; HTTPS/SSH without creds -> denied; default admin/admin rejected. **Ext. tools:** `nmap -p 22,23,80,443 <sw>` (only 22/443); RADIUS test; `ssh -v admin@<sw>`.	HTTPS/SSH authenticate; HTTP/Telnet off; default changed; RADIUS/802.1X where used.	Telnet+HTTP off for SL-3.
SR/CR 1.2	Device & software-process I&A;	Port authentication via **IEEE 802.1X** with RADIUS, plus **MAC security** (per-port allowed MACs); confirm uplink identity. SNMP requires v3 with auth. **Test:** a rogue endpoint on an 802.1X port lands in the restricted VLAN or is denied. **Ext. tools:** 802.1X test supplicant + rogue device; Wireshark `eapol`; RADIUS logs.	Only authenticated devices connect; unknown endpoints quarantined; SNMPv3.	
SR/CR 1.3	Account management	Review named user accounts + privilege (admin/user), least privilege, remove/rename defaults, no shared logins; central auth via RADIUS/TACACS+ where used. **Ext. tools:** Web (user-account review); RADIUS/TACACS+ server review.	Named least-privilege accounts; defaults removed; central auth where used.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers and a unique device identity (hostname/IP - change the default, MAC/serial); no reuse. **Ext. tools:** Web/CLI device info; `nmap -sU -p 161 --script snmp-info`; inventory.	Unique user and device identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Confirm strong, non-default passwords + password policy where available; manage SSH keys / HTTPS certs; strong RADIUS/TACACS+ shared secrets; change SNMP communities. **Ext. tools:** Web (accounts/policy); `ssh-audit <sw>`.	Strong passwords + managed keys/certs; defaults changed.	
SR/NDR 1.6	Wireless access management	**N/A.** Wired switch with no native wireless interface. **Ext. tools:** Confirm no WLAN interface.	N/A - justification recorded (wired network device).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	Confirm the **HTTPS/SSL** certificate is CA-signed/valid (replace the default self-signed), strong keys (>=2048 RSA/ECC); SSH host keys strong; 802.1X/RADIUS certs where used. **Ext. tools:** `sslscan <sw>:443` / `testssl.sh https://<sw>`; `ssh-audit <sw>`.	CA-signed HTTPS cert; strong SSH keys/ciphers; defaults replaced.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm the web/CLI login masks password entry (no cleartext echo) and stored credentials are not cleartext in the config export. **Ext. tools:** Visual verification; config export (no cleartext passwords).	Authenticators obscured during entry and in config.	
SR/CR 1.11	Unsuccessful login attempts	Confirm login lockout/throttling where supported and that failures are logged + **syslogged**/trapped; compensate with monitoring where lockout is limited. **Ext. tools:** Web (lockout config); Hydra (ISOLATED, authorized); syslog/SIEM failed-auth.	Failed logins limited/logged; where limited, compensating monitoring.	
SR/CR 1.12	System use notification	Confirm a login banner/use-notification where supported; also enforce it on the management workstation (GPO). **Ext. tools:** Web/CLI banner config; EWS GPO.	Approved use notice at the switch login + EWS.	
SR/NDR 1.13	Access via untrusted networks	Restrict management: management-access controls (allowed IPs / management VLAN), SSH/HTTPS only; remote admin via VPN + RADIUS/MFA; no management from user/untrusted VLANs. **Test:** from an untrusted VLAN, reach 22/443 -> must fail. **Ext. tools:** `nmap -Pn -p 22,443,161 <sw>` from each VLAN; management-access review.	Management-plane unreachable from untrusted networks; MFA/RADIUS for remote.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Confirm role-based least privilege (admin vs user) - a user-level login cannot change configuration; restrict the admin credential. **Test:** as a user-level login, attempt a config change -> denied and logged. **Ext. tools:** Web (role review); user-level negative test.	Least privilege enforced per role; unauthorized actions denied and logged.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control the engineering laptop and config media; removable-media policy on the EWS; only authorized firmware/config loaded (provenance-verified). **Ext. tools:** EWS removable-media policy; firmware/config provenance.	Portable/engineering media controlled.	
SR/NDR 2.4	Mobile code	**N/A / limited.** No general-purpose app-hosting/mobile-code runtime; confirm only vendor firmware + the web UI run (no user script path). **Ext. tools:** Confirm no scripting/app-hosting; web content vendor read-only.	No mobile-code runtime; only vendor firmware runs.	NDR-specific.
SR/CR 2.5	Session lock	Confirm web/CLI sessions time out on inactivity; enforce the host OS lock on the management workstation. **Ext. tools:** Web/CLI timeout config; host inactivity-lock GPO.	Sessions time out on inactivity; re-auth required.	
SR/CR 2.6	Remote session termination	Confirm management sessions can be viewed/terminated and idle sessions close; concurrent management sessions are bounded. **Ext. tools:** Web/CLI (active sessions); Wireshark (session teardown).	Sessions terminable; concurrency bounded/monitored.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	Confirm the event log + **syslog** (local + remote to the SIEM) capture logins, config changes, 802.1X, and security events with the user identity; named accounts give attribution. **Test:** change config -> a syslog event with user + action + time reaches the SIEM. **Ext. tools:** Web (syslog config); `nc -lu 514` + SIEM; trigger a change.	Security events logged with attribution and forwarded to syslog/SIEM.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.9	Audit storage capacity	Confirm the local log is sized/rotated and offloaded to remote syslog/SIEM, with alerting if the syslog feed fails. **Ext. tools:** Web (log size/remote syslog); SIEM source-silent alert.	Logs sized/offloaded; audit-failure alerting defined.	
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm **NTP/SNTP** time sync so log/syslog timestamps are accurate and correlate. **Ext. tools:** Web (NTP/SNTP config); Wireshark `ntp`.	Accurate, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
NDR 2.13	Physical & diagnostic interfaces	Control physical interfaces: locked cabinet/rack; secure the console and reset; shut/disable unused ports; keep the unit sealed. **Ext. tools:** Physical inspection; web/CLI (unused ports shut).	Console/reset/unused-ports controlled; enclosure sealed.	NDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	Management via **HTTPS/SSH/SNMPv3** only (disable HTTP/Telnet/SNMPv1-2); data-plane segmentation via VLAN; confirm no cleartext management on the wire. **Ext. tools:** Wireshark (encrypted mgmt); `nmap -p 23,80,161 <sw>` (cleartext off).	All management encrypted; cleartext protocols disabled.	
SR/NDR 3.2	Protection from malicious code	Confirm only Red Lion/N-Tron firmware runs. **No documented secure boot / signed-firmware guarantee** on this platform - verify firmware provenance from Red Lion and control the update path (2.3/3.10). **Ext. tools:** Web (firmware version); Red Lion provenance/hash; Red Lion/CISA advisory.	Only vendor firmware runs; provenance verified; no code path.	NDR-specific/Partial.
SR/CR 3.3	Security functionality verification	After any change re-verify: HTTPS/SSH/SNMPv3, HTTP/Telnet off, 802.1X, MAC security, VLANs, N-Ring/RSTP, and firmware, against the hardening baseline; back up + compare the config. **Ext. tools:** Config backup/compare; `nmap -p 22,23,80,443,161 <sw>` (hardened state).	Config matches the hardening baseline; unauthorized change detected.	
SR/CR 3.4	Software & information integrity	Confirm software & information (config/program) integrity; unauthorized change prevented/detected. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Software & information integrity verified individually.	
SR/CR 3.5	Input validation	Confirm the switch tolerates malformed management/protocol frames without instability. **ISOLATED only:** fuzz web/SNMP/RSTP on a bench switch. **Ext. tools:** Protocol fuzzer (ISOLATED); web/CLI CPU/stability.	No instability on malformed input.	Do NOT fuzz an in-service switch.
SR/CR 3.6	Deterministic output	**N/A.** A switch does not drive a physical process output. Confirm the ring/link failure behavior (N-Ring ~30 ms, RSTP/MSTP) is deliberate. **Ext. tools:** Web (N-Ring/RSTP config); ring-break test (lab) -> heal within spec.	N/A - justification recorded; ring/RSTP behavior verified.	N/A
SR/CR 3.7	Error handling	Confirm graceful error handling without info leak; review the event log; port/err behavior deliberate. **Ext. tools:** Web/CLI (event log / port status).	Graceful error handling; no info leak.	
SR/CR 3.8	Session integrity	HTTPS/SSH/SNMPv3 sessions are integrity-protected against replay/hijack; disable weak SSH/TLS ciphers. **Ext. tools:** `ssh-audit <sw>`; `sslscan <sw>:443`.	Strong session crypto; weak algorithms disabled.	
SR/CR 3.9	Protection of audit information	Protect the syslog transport + SIEM store; restrict who can clear the local event log (admin-only); protect config backups. **Ext. tools:** Web (log-access control); SIEM access review; syslog transport.	Audit records protected from unauthorized read/modify/delete.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
NDR 3.10	Support for updates	Update firmware via the web UI with firmware from Red Lion; verify version/provenance; plan a maintenance window with rollback to the prior version. No on-device signature verification - provenance discipline is the control. **Ext. tools:** Web (firmware update); Red Lion provenance/version.	Controlled updates from a verified source, with rollback.	NDR-specific/Partial.
NDR 3.11	Physical tamper resistance/detection	Locked cabinet/rack; control console/reset; event log + syslog record config/firmware changes and restarts as tamper evidence; seal where required. **Ext. tools:** Physical inspection (lock/seal); event-log/syslog review.	Cabinet locked/sealed; interfaces controlled; changes logged.	NDR-specific.
NDR 3.12	Provisioning product-supplier roots of trust	**Partial/N-A.** No documented signed-boot supplier root of trust on this platform. Record the gap; compensate via firmware-provenance discipline (3.10), physical control, and segmentation. **Ext. tools:** Confirm no secure-boot/signed-firmware root; provenance review.	No documented supplier RoT; compensating controls recorded.	Partial/N-A.
NDR 3.13	Provisioning asset-owner roots of trust	Confirm the asset owner can provision its own certificates for HTTPS/802.1X (import CA/cert), replacing the default self-signed; else record the compensating control. **Ext. tools:** Web (certificate import / trust); confirm enterprise CA used.	Asset-owner certificate provisioning verified; defaults replaced.	NDR-specific.
NDR 3.14	Integrity of the boot process	**Partial/N-A.** No documented verified/secure boot. Record the gap; mitigate via firmware-provenance discipline (3.10), physical control, and monitoring. **Ext. tools:** Confirm no secure-boot capability; firmware version.	No documented verified boot; compensating controls recorded.	Partial/N-A.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/RMA, reset to factory defaults (clears config, accounts, keys, certs) and remove saved configs/backups so nothing sensitive is recoverable. **Ext. tools:** Web/CLI (factory reset); confirm saved configs removed.	Config, credentials, keys, and certs purged on decommission.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto: TLS 1.2/1.3 (HTTPS), strong SSH ciphers, SNMPv3 (SHA/AES); CA-signed certs; disable weak/legacy protocols (HTTP/Telnet/SNMPv1-2). **Ext. tools:** `testssl.sh https://<sw>`; `ssh-audit`; SNMPv3 config.	Modern TLS/SSH/SNMPv3; weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	Use **802.1Q VLANs** to isolate zones and a dedicated management VLAN; unused ports in an unused VLAN + shut; confirm the VLAN/port map matches the zone model. **Ext. tools:** Web (VLAN/port map); `nmap` across VLANs to prove isolation.	Effective VLAN segmentation; management VLAN isolated; unused ports shut.	
SR/NDR 5.2	Zone boundary protection	Boundary filtering is at the connected firewall/router + the management-access restriction + MAC security; confirm only required flows cross the zone boundary. **Ext. tools:** `nmap` at the boundary; firewall/VLAN review.	Boundary enforces least-flow; management plane restricted.	
SR/NDR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Network switch with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR 5.4	Application Partitioning	**N/A.** Single-purpose device; no separable applications to partition (handled at the host/SCADA layer).	N/A - justification recorded (not assessed as a control).	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm the event log + remote **syslog** are readable/exportable and forwarded to the SIEM; **N-View / RLView** + a passive OT IDS provide continuous monitoring. **Ext. tools:** Web log export; syslog + SIEM; N-View/RLView; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm resilience: **N-Ring** (~30 ms) + RSTP/MSTP redundancy, IGMP snooping, MAC security, and (where available) storm control/rate limiting bound floods; management-access restriction limits the mgmt-plane surface. **Ext. tools:** Web (N-Ring/RSTP/IGMP status); ISOLATED flood/ring-break test.	Ring/RSTP redundancy + MAC security keep the switch forwarding under fault/load.	
SR/CR 7.2	Resource management	Confirm bounded resources (MAC table, connection/session limits) so a flood cannot exhaust the switch; IGMP snooping controls multicast load. **Ext. tools:** Web/CLI (MAC/IGMP status); bench load test.	Resources bounded; no exhaustion-based loss of forwarding.	
SR/CR 7.3	Control system backup	Confirm the config is backed up (versioned, offline) and a restore is tested on a spare switch for a known-good rebuild. **Ext. tools:** Config backup; restore test (spare switch).	Config backup current; restore/rebuild tested.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden: change default admin/admin + SNMP communities, disable HTTP/Telnet/SNMPv1-2 and unused services, use SNMPv3, restrict management access, enable 802.1X/MAC security, shut unused ports, and patch firmware. **Ext. tools:** Web (services/security config); `nmap -sTU -p 23,80,161,443,22 <sw>` (only required reachable).	Least functionality; insecure services disabled; hardened.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm the switch (model NT24k/7000, firmware, ports) is inventoried so vulnerabilities track against Red Lion / CISA advisories; N-View/RLView aids inventory. **Ext. tools:** `nmap -sU -p 161 --script snmp-info`; N-View/RLView inventory; Red Lion/CISA feeds.	Accurate model/firmware inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Web UI (HTTPS) / CLI (SSH)	Native config review (all FRs)	Log in over HTTPS/SSH (change default admin/admin); review user accounts, 802.1X/RADIUS, SNMPv3, MAC security, syslog, VLAN, N-Ring/RSTP; back up the config.	Read/authorized; unlock only for change tests.
N-View / RLView	NMS monitoring & inventory (2.8, 6.x, 7.8)	Centralized monitoring, ring map/fault charting, and config/version inventory across the Red Lion fleet.	Read-only where possible.
nmap	Port/service exposure & segmentation (1.x, 3.1, 5.x, 7.6)	`nmap -sTU -p 22,23,80,443,161 <sw>`; `nmap -sU -p 161 --script snmp-info`; scan per VLAN; confirm 23/80 closed.	Read-only; authorized.
sslscan / testssl.sh	HTTPS TLS strength (1.8, 3.8, 4.3)	`sslscan <sw>:443` / `testssl.sh https://<sw>`; TLS1.2/1.3 only, strong ciphers, valid cert.	Read-only/safe.
ssh-audit	SSH algorithm strength (1.5, 1.8, 3.8, 4.3)	`ssh-audit <sw>`; strong KEX/cipher/MAC; weak algos disabled.	Read-only.
Wireshark / tcpdump	Comm integrity & monitoring (1.2, 3.1, 6.2)	SPAN/tap; confirm mgmt encrypted, EAPOL on 802.1X ports; inspect N-Ring/RSTP and NTP.	Passive; SPAN/tap only.
802.1X supplicant / RADIUS	Port authentication (1.2)	Present authorized then unauthorized endpoints on an 802.1X port; confirm grant + rogue quarantine in RADIUS logs.	Coordinate with NAC team.
Syslog/SIEM + passive OT IDS	Audit & monitoring (2.8, 6.x)	Confirm the switch forwards security syslog; passive OT IDS for anomaly detection.	Coordinate with SOC.
Red Lion / CISA advisories	Vuln tracking (3.2, 3.10, 7.8)	Track NT24k / N-Tron 7000 advisories and required firmware.	Reference.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.